Topic 1 Connect to a VPN

Difficulty: 3/10. You will, at least:

1. Obtain the Public IP of your Mobile
2. Connect your mobile to a VPN
3. Demonstrate that a VPN alters your public IP
4. Explain why your public IP is different
5. Explain how a VPN can prevent attacks on your mobile

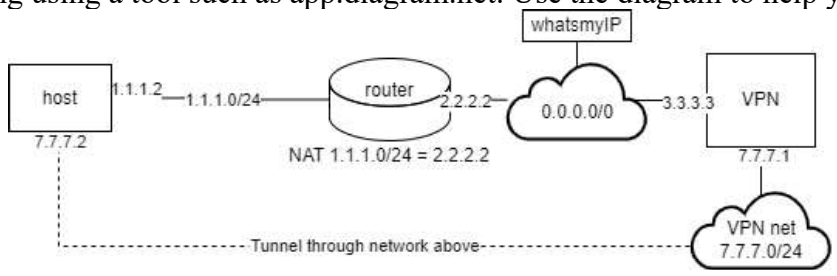
Prepare for your Demonstration Issues

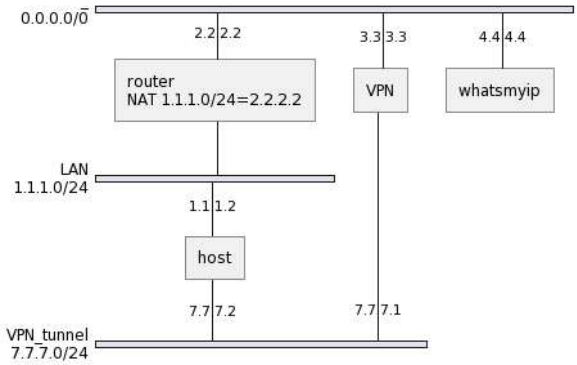
Take screenshots along the way so you could talk about any setup that was required and so that you can continue your demonstration if something happens to make your VM(s) inaccessible. It is not uncommon for VMs to force lengthy updates during demonstrations.

Obtain the Public IP of your Mobile

Your could:

- Show the public IP of a mobile device, for example, by visiting a website such as whatsmyip.
- If your device is behind a NAT, explain why your public IP is different to those of any of your NICs. Draw a network diagram like either of the following using a tool such as app.diagram.net. Use the diagram to help you explain.





You are allowed to use your own mobile device for this demonstration, but you will need to be able to demonstrate your device to an entire class. If you do not wish to use your own mobile device, use the provided Android emulator as discussed below.

Connect Mobile to VPNBook using OpenVPN on Android

- Import the Android VM into VirtualBox
- Install OpenVPN client. You can either log into Google Play and install the OpenVPN client or use F-Droid:

CRICOS Code: 00219C | RTO Code: 40939

BE WHAT YOU WANT TO BE
cqu.edu.au

    - In Android, browse to F-Droid.org and search for OpenVPN apk
    - Change security settings to Allow “Unknown Sources”
    - Open the APK that you downloaded to install OpenVPN
- Browse to VPNBook.com and download an OpenVPN bundle (.zip)
    - Take note of the username and password for later use.
- Open the Terminal, change to /sdcard/Download and use unzip to decompress the .zip archive
- Go to OpenVPN > Settings > Device Specific Hacks and check Use Internal File Browser. If this is not checked, you might not be able to import the .ovpn files in the next step
- Go to OpenVPN > Profiles > Import Profile from OVPN. Import the tcp443 profle.
- Connect to the VPN using the username vpnbook and password.

Demonstrate that a VPN alters your public IP

You could:

- Reshow the public IP, for example, by visiting a website such as whatsmyip.

Explain why your public IP is different

You are encouraged to use tools such as ChatGPT to help draft your explanations. Be sure to provide references. Until there is better guidance, for other assignments in this unit use Harvard website references for ChatGPT. For this assignment, record the ChatGPT version and the question(s) that generated your draft text. You do not need to submit any documents for this task.

Draw and use a network diagram to show the difference in how IP packets are routed when connected and not connected to a VPN.

Explain how a VPN can prevent attacks on your mobile

Topic 2a Demonstrate SmartScreen and RealTime Protection

Difficulty: 4/10. You will, at least:

1. Demonstrate SmartScreen
2. Demonstrate the difference in behaviour when SmartScreen is disabled
3. Demonstrate RealTime Protection
4. Demonstrate the difference in behaviour when RealTime Protection is disabled
5. Explain how SmartScreen and RealTime Protection improve host security and explain the attacks prevented.

Prepare for your Demonstration Issues

Take screenshots along the way so you could talk about any setup that was required and so that you can continue your demonstration if something happens to make your VM(s) inaccessible. It is not uncommon for VMs to force lengthy updates during demonstrations.

Demonstrate Microsoft Defender SmartScreen

You could:

- Visit a site such as DC > https://smartscreentestratings2.net/

Disable Microsoft Defender SmartScreen

You could:

- Visit DC > Edge > edge://settings/?search=smartsc
- Toggle "Microsoft Defender SmartScreen" off

Demonstrate the difference in behaviour when SmartScreen is disabled

You could:

- Revisit https://smartscreentestratings2.net/

Demonstrate RealTime Protection

You could:

- Explain EICAR
- Attempt to download eicar.org/download/eicar.com
- Attempt to run DC PS> C:\tools\Mimikatz\x64\Mimikatz.exe "privilege::debug" "token::elevate" "lsadump::lsa /inject"
  We will investigate this command later in the unit. It is extracting credentials such as passwords from memory. A red error should appear.

Demonstrate the difference in behaviour when RealTime Protection is disabled

You could:

- Go to DC > Virus & Threat Protection
- Go to Virus & Threat Protection > Manage settings
- Toggle "Real-time protection" off
- Redownload eicar.org/download/eicar.com
- Rerun DC PS> C:\tools\Mimikatz\x64\Mimikatz.exe "privilege::debug" "token::elevate" "lsadump::lsa /inject"

This time the program will run and hashes of passwords will be output to the screen. The output is not important to understand at this stage of the unit.

Explain how SmartScreen and RealTime Protection improve host security and explain the attacks prevented.

You are encouraged to use tools such as ChatGPT to help draft your explanations. Be sure to provide references. Until there is better guidance, for other assignments in this unit use Harvard website references for ChatGPT. For this assignment, record the ChatGPT version and the question(s) that generated your draft text. You do not need to submit any documents for this task.

Topic 2b Demonstrate SmartScreen and Attack Surface Reduction

Difficulty: 4/10. You will, at least:

1. Demonstrate SmartScreen
2. Demonstrate the difference in behaviour when SmartScreen is disabled
3. Demonstrate lsass Credential Dumping
4. Block lsass Credential Dumping using Attack Surface Reduction (ASR)
5. Explain how SmartScreen and Attack Surface Reduction improve host security and explain the attacks prevented.

Prepare for your Demonstration Issues

Take screenshots along the way so you could talk about any setup that was required and so that you can continue your demonstration if something happens to make your VM(s) inaccessible. It is not uncommon for VMs to force lengthy updates during demonstrations.

Demonstrate Microsoft Defender SmartScreen

You could:

- Visit a site such as DC > https://smartscreentestratings2.net/

Disable Microsoft Defender SmartScreen

You could:

- Visit DC > Edge > edge://settings/?search=smartsc
- Toggle "Microsoft Defender SmartScreen" off

Demonstrate the difference in behaviour when SmartScreen is disabled

You could:

- Revisit https://smartscreentestratings2.net/

Demonstrate lsass Credential Dumping

You could:

- Attempt to run DC PS> C:\tools\Mimikatz\x64\Mimikatz.exe "privilege::debug" "token::elevate" "lsadump::lsa /inject"
  We will investigate this command later in the unit. It is extracting credentials such as passwords from memory. A red error should appear.

Block lsass Credential Dumping using Attack Surface Reduction (ASR)

You could:

- DC PS> Set-MpPreference -AttackSurfaceReductionRules_Ids 9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2 -AttackSurfaceReductionRules_Actions Enabled
- Rerun DC PS> C:\tools\Mimikatz\x64\Mimikatz.exe "privilege::debug" "token::elevate" "lsadump::lsa /inject"
  This time, the program will run but errors will be generated instead of hashes.

Explain how SmartScreen and Attack Surface Reduction improve host security and explain the attacks prevented.

You are encouraged to use tools such as ChatGPT to help draft your explanations. Be sure to provide references. Until there is better guidance, for other assignments in this unit use Harvard website references for ChatGPT. For this assignment, record the ChatGPT version and the question(s) that generated your draft text. You do not need to submit any documents for this task.

Topic 3 Demonstrate Data Execution Prevention (DEP)

Difficulty: 4/10. This demonstration contains moderately complex concepts that might be difficult to explain. You will, at least:

1. Explain JIT and DEP and the differences between them
2. Demonstrate how JIT can be used to run code 'compiled' at run-time
3. Demonstrate how DEP prevents code in protected data pages from running
4. Demonstrate how disabling DEP does not prevent running code in protected data pages
5. Explain how DEP improves host security including the attacks prevented.

Prepare for your Demonstration Issues

Take screenshots along the way so you could talk about any setup that was required and so that you can continue your demonstration if something happens to make your VM(s) inaccessible. It is not uncommon for VMs to force lengthy updates during demonstrations.

Explain JIT and DEP and the differences between them

You could:

- Download DEP.zip from the unit website inside DC > Edge.
- Explain how the shellcode_JIT.c code works
- Explain the differences compared with the shellcode_DEP.c code

Demonstrate how JIT can be used to run code 'compiled' at run-time

You could:

- DC: Run shellcode_JIT.exe.

Demonstrate how DEP prevents code in protected data pages from running

You could

- Show the error produced with shellcode_DEP.exe is run.

Demonstrate how disabling DEP does not prevent running code in protected data pages

You could:

- Search for and run "Exploit Protection"
- Go to Program Settings and add shellcode_DEP.exe
- Disable DEP for shellcode_DEP.exe

Explain how DEP improves host security including the attacks prevented.

You are encouraged to use tools such as ChatGPT to help draft your explanations. Be sure to provide references. Until there is better guidance, for other assignments in this unit use Harvard website references for ChatGPT. For this assignment, record the ChatGPT version and the question(s) that generated your draft text. You do not need to submit any documents for this task.

CRICOS Provider Code: 00213J, RTO Code: 40803

If time permits, you could further demonstrate JIT by writing code that modifies the shellcode at run time. Alternatively you could try to demonstrate other exploit protections such as ASLR. Alternatively, you could show how DEP can be bypassed.